UNIT 2

Hackers and Cyber Crimes

Hacking:

Hacking has been a part of computing for 40 years.

- The first computer hacker emerged at MIT.
- Hacking began in the 1960s at MIT, origin of the term "hacker".
- The truth hacker amongst our societies have thirst for the knowledge.
- Boredom is never an object of challenge for the hacker

What is Hacking?

- The Process of attempting to gain or successfully gaining, unauthorized access to computer resources is called Hacking.

Who is a hacker?

- In the computer security context, a hacker is someone who seeks and exploits weaknesses in a computer system or computer network.
- The term hacker is reclaimed by computer programmers who argue that someone breaking into computers is better called a cracker.

Note: Famous Hackers in History Ian Murphy Kevin Mitnick Mark Abene Johan Helsinguis Linus Torvalds Robert Morris

Hacking: Hacking may be defined as the technique or planning which is done to get an access to unauthorized systems. Simply we can say to gaining access to a network or a computer for illegal purposes. The person who does that are very intelligent and skilled in computers.
The person who are skilled in Hacking are divided into 2 categories:

1. **Hackers:** Hackers are kind of good peoples who does hacking for the good purpose and to obtain more knowledge from it. They generally find loop holes in the system and help them to cover the loop holes. Hackers are generally programmers who obtain advance knowledge about operating systems and programming languages. These people never damage or harm any kind of data.
2. **Crackers:** Crackers are kind of bad people who breaks or violates the system or a computer remotely with bad intentions to harm the data and steal it. Crackers destroy data by gaining an unauthorized access to the network. There works are always hidden as they are doing illegal stuff. Bypasses passwords of computers

and social media websites, can steal your bank details and transfer money from bank.

Difference between Hackers and Crackers:

Hacker	Cracker
The good people who hack for knowledge purposes.	The evil person who breaks into a system for benefits.
They are skilled and have a advance knowledge of computers OS and programming languages.	They may or may not be skilled, some of crackers just knows a few tricks to steal data.
They work in an organisation to help protecting their data and giving them expertise on internet security.	These are the person from which hackers protect organisations.
Hackers share the knowledge and never damages the data.	If they found any loop hole, they just delete the data or damages the data.
Hackers are the ethical professionals.	Crackers are unethical and want to benefit themselves from illegal tasks.
Hackers program or hacks to check the integrity and vulnerability strength of a network.	Crackers do not make new tools but use someone else tools for their cause and harm the network.
Hackers have legal certificates with them e.g CEH certificates.	Crackers may or may not have certificates, as their motive is to stay anonymous.

Famous Hackers

In this section, we will see some of the famous hackers and how they become famous.

Jonathan James

Jonathan James was an *American hacker*. He is the first Juvenile who send to prison for *cybercrime* in the United States. He committed suicide on **18 May 2008**, of a self-inflicted gunshot wound.

In 1999, at the age of 16, he gained access to several computers by breaking the password of a *NASA* server and stole the source code of International Space Station, including control of the temperature and humidity within the living space.

Kevin Mitnick

He is a computer security consultant, author, and hacker. He infiltrates his client's companies to expose their security strengths, weaknesses, and potential loopholes. In the history of the United States, he was formerly the most wanted computer criminal.

From the *1970s* up until his last arrest in *1995*, he skilfully bypassed corporate security safeguards and found his way into some of the most well-guarded systems like Sun Microsystems, Nokia, Motorola, Netcom, Digital Equipment Corporation.

Mark Abene

Mark Abene is an *American Infosec expert and Entrepreneur*. He is known around the world by his pseudonym Phiber Optik. Once, he was a member of the *hacker* groups Legion of Doom and Master of Deception. He was a high profile hacker in the *1980s* and early *1990s*.

He openly debated and defended the positive merits of ethical hacking as a beneficial tool for the industry. He is also expert in penetration studies, security policy review and generation, on-site security assessments, systems administration, and network management, among many others.

Robert Morris

Robert Morris was the creator of the *Morris Worm*. He was the first computer worm to be unleashed on the Internet. The Morris Worm had the capability to slow down computers and make them no longer usable. Due to this, he was sentenced to three years probation, *400 hours* of community service and also had to pay a penalty amount of *$10,500*.

Gary McKinnon

Gary McKinnon is a *Scottish systems administrator and Hacker*. In 2002, he was accused of the **"biggest military computer hack of all time"**. He has successfully hacked the network of Navy, Army, Air Force, NASA system of the United States Government.

In his statement to the media, he has often mentioned that his motivation was only to find evidence of UFOs and the suppression of *"free energy"* that could potentially be useful to the public.

Linus Torvalds

Linus Torvalds is a Finnish-American *software engineer* and one of the best hackers of all the time. He is the developer of the very popular *Unix-based* operating system called as Linux. Linux operating system is open source, and thousands of developers have contributed to its kernel. However, he remains the ultimate authority on what new code is incorporated into the standard Linux kernel.

Torvalds just aspire to be simple and have fun by making the *world's* best operating system. Linus Torvalds has received honorary doctorates from University of Helsinki and Stockholm University.

Kevin Poulsen

Kevin Poulsen is an American former *Black-hat* hacker. He is also known as Dark Dante. He took over all the telephone lines of radio station KIIS-FM of Los Angeles, guaranteeing that he would be the 102nd caller and win the prize of a Porsche 944 S2.

Poulsen also drew the ire of *FBI*, when he hacked into federal computers for wiretap information. As a result of this, he was sentenced for five years. He has reinvented himself as a journalist.

Types of Hackers

Hackers can be classified into three different categories:

1. Black Hat Hacker
2. White Hat Hacker
3. Grey Hat Hacker



Black Hat Hacker

Black-hat Hackers are also known as an **Unethical Hacker or a Security Cracker**. These people hack the system illegally to steal money or to achieve their own illegal goals. They find banks or other companies with weak security and steal money or credit card information. They can also modify or destroy the data as well. Black hat hacking is illegal.



White Hat Hacker

White hat Hackers are also known as **Ethical Hackers or a Penetration Tester**. White hat hackers are the good guys of the hacker world.

These people use the same technique used by the black hat hackers. They also hack the system, but they can only hack the system that they have permission to hack in order to test the security of the system. They focus on security and protecting IT system. White hat hacking is legal.

Gray Hat Hacker

Gray hat Hackers are Hybrid between Black hat Hackers and White hat hackers. They can hack any system even if they don't have permission to test the security of the system but they will never steal money or damage the system.

In most cases, they tell the administrator of that system. But they are also illegal because they test the security of the system that they do not have permission to test. Grey hat hacking is sometimes acted legally and sometimes not.

Types of Hacking

- Website Hacking
- Network Hacking
- Ethical Hacking
- Email Hacking
- Password Hacking
- Online Banking Hacking
- Computer Hacking

Website Hacking: Hacking a website means taking control from the website owner to a person who hacks the website.

Network Hacking: Network Hacking is generally means gathering information about domain by using tools like Telnet, Ns look UP, Ping, Tracert, Netstat, etc… over the network.

Ethical Hacking: Ethical hacking is where a person hacks to find weaknesses in a system and then usually patches them.

Email Hacking: Email hacking is illicit access to an email account or email correspondence.

Password Hacking: Password Hacking Password cracking is the process of recovering secret passwords from data that has been stored in or transmitted by a computer system.

Online Banking Hacking: Online banking Hacking Unauthorized accessing bank accounts without knowing the password or without permission of account holder is known as Online banking hacking.

Computer Hacking: Computer Hacking is when files on your computer are viewed, created, or edited without your authorization.

What should do after hacked?

- Shutdown the system − Or turn off the system
- Separate the system from network
- Restore the system with the backup − Or reinstall all programs
- Connect the system to the network It can be good to call the police

How to give a password to account?

- Use unique passwords for your accounts.
- Choose a combination of letters, numbers, or symbols to create a unique password.

What is Vulnerability in Computer Security and How is It Different from a Cyber Threat?

To put it in the most basic terms, a computer system vulnerability is a flaw or weakness in a system or network that could be exploited to cause damage, or allow an attacker to manipulate the system in some way.

This is different from a "cyber threat" in that while a cyber threat may involve an outside element, computer system vulnerabilities exist on the network asset (computer) to begin with. Additionally, they are not usually the result of an intentional effort by an attacker—though cybercriminals will leverage these flaws in their attacks, leading some to use the terms interchangeably.

The way that a computer vulnerability is exploited depends on the nature of the vulnerability and the motives of the attacker. These vulnerabilities can exist because of unanticipated

interactions of different software programs, system components, or basic flaws in an individual program.

Here are a few securities vulnerability and security threat:

1) Malware

As pointed out earlier, new malware is being created all the time. However, while the statistic of 360,000 new malware files a day sounds daunting, it's important to know one thing: Many of these "new" malware files are simply rehashes of older malware programs that have been altered just enough to make them unrecognizable to antivirus programs.

Over the years, however, many different kinds of malware have been created, each one affecting the target's systems in a different way:

- **Ransomware.** This malicious software is designed to encrypt the victim's data storage drives, rendering them inaccessible to the owner. An ultimatum is then delivered, demanding payment in return for the encryption key. If the ransom demand isn't met, the key will be deleted and the data lost forever with it.

- **Trojans.** This references a kind of delivery system for malware. A Trojan is any piece of malware that masquerades as a legitimate program to trick victims into installing it on their systems. Trojans can do a lot of damage because they slip behind your outermost network security defenses by posing as something harmless while carrying a major threat inside — like a certain infamous horse did to the city of Troy in Homer's "Iliad."

- **Worms.** Worms are programs that can self-replicate and spread through a variety of means, such as emails. Once on a system, the worm will search for some form of contacts database or file sharing system and send itself out as an attachment. When in email form, the attachment is part of an email that looks like it's from the person whose computer was compromised.

The goal of many malware programs is to access sensitive data and copy it. Some highly-advanced malwares can autonomously copy data and send it to a specific port or server that an attacker can then use to discreetly steal information.

Basic antivirus can protect against some malwares, but a multilayered security solution that uses antivirus, deep-packet inspection firewalls, intrusion detection systems (IDSs), email virus scanners, and employee awareness training is needed to provide optimal protection.

2) Unpatched Security Vulnerabilities

While there are countless new threats being developed daily, many of them rely on old security vulnerabilities to work. With so many malwares looking to exploit the same few vulnerabilities time and time again, one of the biggest risks that a business can take is failing to patch those vulnerabilities once they're discovered.

It's all too common for a business—or even just the individual users on a network—to dismiss the "update available" reminders that pop up in certain programs because they don't want to lose the 5-10 minutes of productive time that running the update would take. Updating is a nuisance to most users. However, it's a "nuisance" that could save a business untold amounts of time, money, and lost business later.

The easy fix is to maintain a regular update schedule—a day of the week where your IT team checks for the latest security patches for your organization's software and ensures that they're applied to all of your company's systems.

3) Hidden Backdoor Programs

This is an example of an intentionally-created computer security vulnerability. When a manufacturer of computer components, software, or whole computers installs a program or bit of code designed to allow a computer to be remotely accessed (typically for diagnostic, configuration, or technical support purposes), that access program is called a backdoor.

When the backdoor is installed into computers without the user's knowledge, it can be called a hidden backdoor program. Hidden backdoors are an enormous software vulnerability because they make it all too easy for someone with knowledge of the backdoor to illicitly access the affected computer system and any network it is connected to.

For example, a recent article by Bloomberg highlights a case where a security vulnerability that could be used as a backdoor was left in a manufacturer's routers. According to the author:

"Europe's biggest phone company identified hidden backdoors in the software that could have given Huawei unauthorized access to the carrier's fixed-line network in Italy, a system that provides internet service to millions of homes and businesses… Vodafone asked Huawei to remove backdoors in home internet routers in 2011 and received assurances from the supplier that the issues were fixed, but further testing revealed that the security vulnerabilities remained."

This software vulnerability in the Huawei routers is concerning because, if used by malicious actors, it could give them direct access to millions of networks.

4) Superuser or Admin Account Privileges

One of the most basic tenets of managing software vulnerabilities is to limit the access privileges of software users. The less information/resources a user can access, the less damage that user account can do if compromised.

However, many organizations fail to control user account access privileges—allowing virtually every user in the network to have so-called "Superuser" or administrator-level access. Some computer security configurations are flawed enough to allow unprivileged users to create admin-level user accounts.

Verifying that user account access is restricted to only what each user needs to do their job is crucial for managing computer security vulnerabilities. Also, ensuring that newly-created

accounts cannot have admin-level access is important for preventing less-privileged users from simply creating more privileged accounts.

5) Automated Running of Scripts without Malware/Virus Checks

One common network security vulnerability that some attackers learned to exploit is the use of certain web browsers' (such as Safari) tendencies to automatically run "trusted" or "safe" scripts. By mimicking a trusted piece of code and tricking the browser, cybercriminals could get the browser software to run malware without the knowledge or input of the user—who often wouldn't know to disable this "feature."

While keeping employees from visiting untrustworthy websites that would run malware is a start, disabling the automatic running of "safe" files is much more reliable—and necessary for compliance with the Center for Internet Security's (CIS') AppleOS benchmark.

6) Unknown Security Bugs in Software or Programming Interfaces

Computer software is *incredibly* complicated. When two or more programs are made to interface with one another, the complexity can only increase. The issue with this is that within a single piece of software, there may be programming issues and conflicts that can create security vulnerabilities. When two programs are interfaced, the risk of conflicts that create software vulnerabilities rises.

Programming bugs and unanticipated code interactions rank among the most common computer security vulnerabilities—and cybercriminals work daily to discover and abuse them. Unfortunately, predicting the creation of these computer system vulnerabilities is nearly impossible because there are virtually no limits to the combinations of software that might be found on a single computer, let alone an entire network.

7) Phishing (Social Engineering) Attacks

In a phishing attack, the attacker attempts to trick an employee in the victim organization into giving away sensitive data and account credentials—or into downloading malware. The most common form of this attack comes as an email mimicking the identity of one of your company's vendors or someone who has a lot of authority in the company.

For example, the attacker may say something like: "This is Mark from IT, your user account shows suspicious activity, please click this link to reset and secure your password." The link in such an email often leads to a website that will download malware to a user's computer, compromising their system. Other phishing attacks may ask users to give the attacker their user account credentials so they can solve an issue.

The basic goal of this strategy is to exploit an organization's employees to bypass one or more security layers so they can access data more easily.

There are several ways to defend against this attack strategy, including:

- **Email Virus Detection Tools.** To check email attachments for malware that could harm your network.

- **Multifactor Authentication (MFA).** Using multiple authentication methods (such as biometrics, one-use texted codes, and physical tokens) for giving users access to your network makes it harder for attackers to hijack user accounts with just the username and password.

- **Employee Cybersecurity Awareness Training.** An educated employee is less likely to fall for phishing schemes than one who doesn't know basic cybersecurity protocols. Cybersecurity awareness training helps to provide employees with the basic knowledge they need to identify and avoid phishing attacks.

- **Defence in Depth.** Using a defence-in-depth approach to network security adds extra layers of protection between each of the individual assets on the network. This way, if attackers bypass the outermost defences of the network, there will still be other layers of protection between the compromised asset and the rest of the network.

- **Policy of Least Privilege.** Enacting a policy of least privilege means restricting a user's access to the minimum amount needed to perform their job duties. This way, if that user's account privileges are misused, the damage will be limited.

8) Your IoT Devices

The Internet of Things (IoT) encompasses many "smart" devices, such as Wi-Fi capable refrigerators, printers, manufacturing robots, coffee makers, and countless other machines. The issue with these devices is that they can be hijacked by attackers to form slaved networks of compromised devices to carry out further attacks. Worse yet, many businesses don't even realize just how many IoT devices they have on their networks—meaning that they have unprotected vulnerabilities that they aren't aware of.

These unknown devices represent a massive opportunity to attackers—and, a massive risk for businesses.

To minimize the risk from IoT devices, a security audit should be performed that identifies all of the disparate assets on the network and the operating systems they're running. This way, these IoT devices can be properly accounted for in the company's cybersecurity strategy. Such audits should be performed periodically to account for any new devices that may be added to the network over time.

9) Your Own Employees

The biggest security vulnerability in any organization is its own employees. Whether it's the result of intentional malfeasance or an accident, most data breaches can be traced back to a person within the organization that was breached.

For example, employees may abuse their access privileges for personal gain. Or, an employee may click on the wrong link in an email, download the wrong file from an online site, or give the wrong person their user account credentials—allowing attackers easy access to your systems.

Some of the same prevention techniques mentioned in the anti-phishing bullets can be applied to prevent data breaches caused by employees.

For example, using a policy of least privilege keeps users from having access to too much data at once, making it harder for them to steal information. Additionally, cybersecurity awareness training helps employees spot phishing attempts and other social engineering-style attacks so they won't fall for them.

How to Find Security Vulnerabilities

One of the most important steps in preventing a security breach is identifying security vulnerabilities before an attacker can leverage them. But, many organizations lack the tools and expertise to identify security vulnerabilities. To help your business improve its cybersecurity, here are some tips for how to find security vulnerabilities:

How to Find Security Vulnerabilities: Audit Your Network Assets

To find security vulnerabilities on the business' network, it is necessary to have an accurate inventory of the assets on the network, as well as the operating systems (OSs) and software these assets run. Having this inventory list helps the organization identify security vulnerabilities from obsolete software and known program bugs in specific OS types and software.

Without this inventory, an organization might assume that their network security is up to date, even though they could have assets with years-old vulnerabilities on them. Also, if a new security protocol is applied to assets on the network to close security gaps, but there are unknown assets on the network, this could lead to uneven protection for the organization.

For example, say that Servers A, B, and C get updated to require multi-factor authentication, but Server D, which was not on the inventory list, doesn't get the update. Malicious actors could use this less-secure server as an entry point in an attack. Breaches have occurred in this manner before. As noted by *The New York Times* in an article about a major data breach affecting JPMorgan Chase bank, "Most big banks use a double authentication scheme, known as two-factor authentication, which requires a second one-time password to gain access to a protected system. But JPMorgan's security team had apparently neglected to upgrade one of its network servers with the dual password scheme."

When it comes to finding security vulnerabilities, a thorough network audit is indispensable for success.

How to Find Security Vulnerabilities: Penetration Testing

After completing the audit of the network and inventorying every asset, the network needs to be stress-tested to determine how an attacker might try to break it. Such penetration testing is

how cybersecurity professionals check for security gaps so they can be closed before a malicious attack occurs.

The methodology behind a penetration test may vary somewhat depending on the organization's network security architecture and cybersecurity risk profile—there is no true "one size fits all" approach to penetration testing. However, the general steps of a penetration test usually involve:

1. Getting a "white hat" hacker to run the pen test at a set date/time.
2. Auditing existing systems to check for assets with known vulnerabilities.
3. The "hackers" running simulated attacks on the network that attempt to exploit potential weaknesses or uncover new ones.
4. The organization running its incident response plan (IRP) to try and contain the "attacks" simulated during penetration testing.

In addition to identifying security vulnerabilities, the last item on the list can also help to find deficiencies in the company's incident response. This can be useful for modifying response plans and measures to further reduce exposure to some cybersecurity risks.

How to Find Security Vulnerabilities: Creating a Threat Intelligence Framework

Penetration testing is highly useful for finding security vulnerabilities. However, it isn't the only method companies should use. Another tool for identifying potential issues is the threat intelligence framework. This framework helps your organization:

- Define what it needs to protect.
- Set goals for overall network security.
- Identify primary threat sources.
- Refine cybersecurity protections.
- Choose appropriate threat intelligence feeds to monitor new and emerging cyber threats and attack strategies.

Knowing what your biggest network security threats are is crucial for keeping your cybersecurity protection measures up to date. This is where many companies turn to a managed security services provider (MSSP), since these cybersecurity experts will often have tools and experience that make creating a threat intelligence framework easier.

Many MSSPs can provide penetration testing and vulnerability management services to quickly identify major network security issues—and then help their customers close those security gaps before an attacker can leverage them. MSSPs can also help create or modify incident response plans so companies can minimize the impacts if a network security breach does unfortunately occur.

Knowing what the biggest threats to your business are is the first step to protecting your (and your customers') sensitive data. However, it takes a lot of hard work, expertise, and vigilance to minimize your cybersecurity risks. If you need help setting up a strong cybersecurity architecture to protect your business, contact Compuquip Cybersecurity today! We're here to help you minimize your risks and protect your business.

What are Malware Threats on Computer?

Malware is a malicious software that is dangerous to the computer. Once installed, malware can harm the computer in different ways. To have a better understanding of malware threats. Let's find out first how does one get malware on the computer.

Where Malware Threats come from

Malware is spread on different websites on the Internet. Hackers are clever these days; they don't just insert malware in non-secure websites but also on legitimate websites. How do they do this?

Hackers use different techniques to lure in victims.

1. Social Engineering

Social engineering is a technique that makes a user want to give away personal information. Think of it this way; a present is ready to be shipped, you just have to provide your address.

Who would refuse a present? If you are unaware of how malware works, you will fall into this trick. Rather than installing malware intrusively, they've developed a strategy for the user to install malware willingly.

By presenting malware in an engaging way, it is easy to convince users into installing malware on their computer. What are the examples of social engineering?

Email

One example of a social engineering email is a fake email from a friend or family. It may contain a message saying that there's a funny picture of you, click here to view the image.

This may trigger curiosity. Who doesn't want to see his own funny photo, right? If you have no idea that it's a form of social engineering, you will download the attachment and install malware without knowing it.

So how to prevent malware from fake emails? Send your contact a separate email to confirm if the email is legit.

Fake Downloads

Social engineering can use a threat to convince their victim. You could just be browsing the Internet, suddenly a message flashes on the screen saying that there's a threat detected, click here to download an antivirus.

Don't fall for this trick. Threats can be resolved by downloading a trustworthy antivirus software.

Phishing Link

Do you know that a phishing link generates a fake login page to collect information and install malware? This is most common in-game cheats and hacks. A hacker can easily add a link that redirects the user to a fake website that contains dangerous malware.

So how to avoid phishing links? Use the free website scanner on the Internet to verify if the link is safe. You may use Website Inspector by Comodo or other third party websites.

2. Website Cookie Exploitation

Cookies are sent from a browser to a server over a secure HTTPS connection. However, hackers have found a way to inject fake cookies that can bypass HTTPS security.

These malicious cookies can be used to install malware such as Trojan and to redirect the user to a fake website.

Now that we know where malware threats come from, what are malware threats exactly?

Malware is an application that is designed to steal personal information and destroy computer data without being exposed. Hackers use different types of malware to invade the computer.

What are the types of Malware?

Virus

A virus is a self-replicating malware that infects the computer through an executable file. It is attached to a file that the user must run first for the virus to spread. Note that it cannot activate itself without a human help.

Worm

A worm is the opposite of virus. If a virus needs a human action to self-replicate, a worm can spread independently. Once installed, worm replicates fast and consumes the computer memory that leads in low disk space and reduced computer performance.

Trojan

Is a type of malware that is used to gain control over the computer. Trojan installs other types of malware used to manipulate the computer without the user's knowledge. This allows hackers to use the computer for delivering cybercrimes.

Spyware

Spyware is used to monitor computer activities to gather personal information. Spyware allows hackers to view emails, listen to phone calls, and watch the victim through the webcam.

Keylogger

Keylogger exposes the passwords by recording each key pressed on the keyboard. It is used to steal account information.

Rootkit

Targets the operating system, making it hard to detect. A rootkit is invisible in Task Manager since it's built in the operating system of the computer. It is used to conceal malware activities on the computer. It's often bundled with another malware to steal bank account information.

How Does Malware Spread?

Each type of malware has its own unique way of causing havoc, and most rely on user action of some kind. Some strains are delivered over email via a link or executable file. Others are delivered via instant messaging or social media. Even mobile phones are vulnerable to attack. It is essential that organizations are aware of all vulnerabilities so they can lay down an effective line of defence.

How to Protect Against Malware

Now that you understand a little more about malware and the different flavors it comes in, let's talk about protection. There are actually two areas to consider where protection is concerned: protective tools and user vigilance. The first is often the easiest to implement, simply because you can often set and forget best-in-class protective software that manages and updates itself. Users, on the other hand, can be prone to temptation ("check out this cool website!") or easily led by other emotions such as fear ("install this antivirus software immediately"). Education is key to ensure users are aware of the risk of malware and what they can do to prevent an attack.

With good user policies in place and the right anti-malware solutions constantly monitoring the network, email, web requests and other activities that could put your organization at risk, malware stands less of a chance of delivering its payload. **Forcepoint's Advanced Malware Detection** offers best-in-class malware protection across multiple channels and is unmatched in security efficacy.

SNIFFING

Sniffing is the process of monitoring and capturing all the packets passing through a given network using sniffing tools. It is a form of "tapping phone wires" and get to know about the conversation. It is also called **wiretapping** applied to the computer networks.

There is so much possibility that if a set of enterprise switch ports is open, then one of their employees can sniff the whole traffic of the network. Anyone in the same physical location can plug into the network using Ethernet cable or connect wirelessly to that network and sniff the total traffic.

In other words, Sniffing allows you to see all sorts of traffic, both protected and unprotected. In the right conditions and with the right protocols in place, an attacking party may be able to gather information that can be used for further attacks or to cause other issues for the network or system owner.

What can be sniffed?

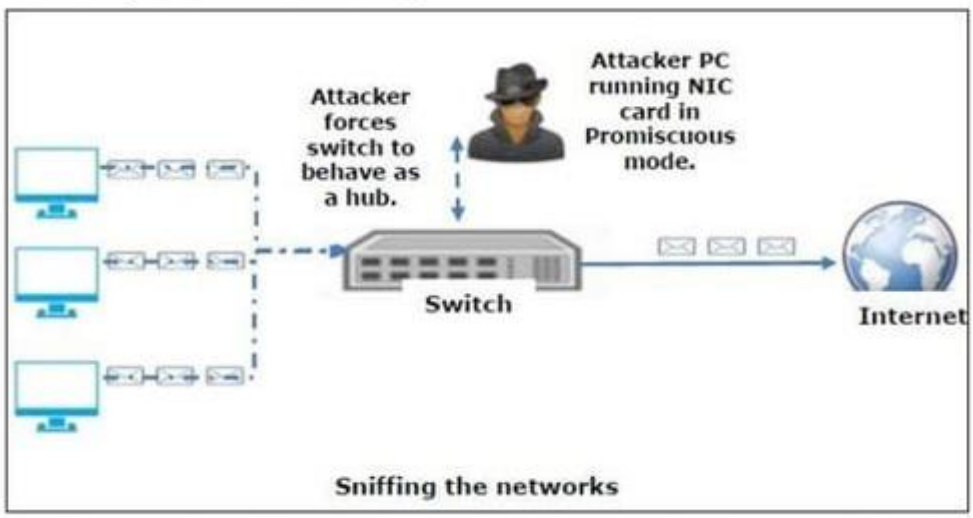
One can sniff the following sensitive information from a network −

- Email traffic
- FTP passwords
- Web traffics
- Telnet passwords
- Router configuration
- Chat sessions
- DNS traffic

How it works

A sniffer normally turns the NIC of the system to the **promiscuous mode** so that it listens to all the data transmitted on its segment.

Promiscuous mode refers to the unique way of Ethernet hardware, in particular, network interface cards (NICs), that allows an NIC to receive all traffic on the network, even if it is not addressed to this NIC. By default, a NIC ignores all traffic that is not addressed to it, which is done by comparing the destination address of the Ethernet packet with the hardware address (a.k.a. MAC) of the device. While this makes perfect sense for networking, non-promiscuous mode makes it difficult to use network monitoring and analysis software for diagnosing connectivity issues or traffic accounting.



Sniffing the networks

A sniffer can continuously monitor all the traffic to a computer through the NIC by decoding the information encapsulated in the data packets.

Types of Sniffing

Sniffing can be either Active or Passive in nature.

Passive Sniffing

In passive sniffing, the traffic is locked but it is not altered in any way. Passive sniffing allows listening only. It works with Hub devices. On a hub device, the traffic is sent to all the ports. In a network that uses hubs to connect systems, all hosts on the network can see the traffic. Therefore, an attacker can easily capture traffic going through.

The good news is that hubs are almost obsolete nowadays. Most modern networks use switches. Hence, passive sniffing is no more effective.

Active Sniffing

In active sniffing, the traffic is not only locked and monitored, but it may also be altered in some way as determined by the attack. Active sniffing is used to sniff a switch-based network. It involves injecting **address resolution packets** (ARP) into a target network to flood on the switch **content addressable memory** (CAM) table. CAM keeps track of which host is connected to which port.

Following are the Active Sniffing Techniques −

- MAC Flooding
- DHCP Attacks
- DNS Poisoning
- Spoofing Attacks
- ARP Poisoning

Gaining Access

Gaining access attack is the second part of the network penetration testing. In this section, we will connect to the network. This will allow us to launch more powerful attacks and get more accurate information. If a network doesn't use encryption, we can just connect to it and sniff out unencrypted data. If a network is wired, we can use a cable and connect to it, perhaps through changing our MAC address. The only problem is when the target use encryption like WEP, WPA, WPA2. If we do encounter encrypted data, we need to know the key to decrypt it, that's the main purpose of this chapter.

If the network uses encryption, we can't get anywhere unless we decrypt it. In this section, we will discuss that how to break that encryption and how to gain access to the networks whether they use WEP/WPA/WPA2.

This section will cover the following topics:

- WEP Introduction
- Basic WEP cracking

- Fake authentication attack
- ARP request replay
- WPA theory
- Handshake theory
- Capturing handshakes
- Creating wordlists
- Wordlist cracking
- Securing network from attacks

The goal here is to collect enough information to gain access to the target.

Password Cracking:

There are few basic methods of password cracking:

1. Bruteforce: trying all possible combinations until the password is cracked.
2. Dictionary attack: This is a compiled list of meaningful words, compared against the password field till a match is found.
3. Rule based attack: If some details about the target are known, we can create rules based on the information we know.
4. Rainbow table: Instead of comparing the passwords directly, taking the hash value of the password, comparing them with a list of pre-computed hash values until a match is found.

Rainbow table method gives an advantage to the attacker since no account lockout is enabled for wrong hashes against the password. To prevent rainbow table attack, salting can be used. Salting is a process of adding random numbers to the password so the attacker will not be able to crack the hash without that salt added.

Types of Password Attacks

Passive online attacks

A passive attack is an attack on a system that does not result in a change to the system in any way.

The attack is to purely monitor or record data.

- Wire Sniffing
- Man in the middle
- Replay attack

Active online attack

An active online attack is the easiest way to gain unauthorized administrator-level access to the system

- Password guessing
- Trojan/spyware/keyloggers

- Hash injection
- Phishing

Offline attacks

Offline attacks occur when the intruder checks the validity of the passwords. Offline attacks are often time to consume.

- Pre-computed hashes
- Distributed Network
- Rainbow

Non-electronic attacks

Non-electronic attacks are also known as non-technical attacks. This kind of attack doesn't require any technical knowledge about the methods of intruding into another system.

- Social engineering
- Shoulder surfing
- Dumpster Diving

How to defend against password cracking:

- Don't share your password with anyone
- Do not use the same passwords during password change
- Enable security auditing to help monitor and track password attack
- Do not use cleartext protocols and protocols with weak encryption
- Set the password change policy to 30 days
- Monitor the server's logs for brute force attacks on the user's accounts
- Avoid storing passwords in an unsecured location
- Never use passwords such as date of birth, spouse, or child's or pet's name
- Enable SYSKEY with the strong password to encrypt and protect the SAM database
- Lockout an account subjected to too many incorrect password guesses.

Privilege Escalation

Privilege escalation can be defined as an attack that involves gaining illicit (illegal) access of elevated rights, or privileges, beyond what is intended or entitled for a user. This attack can involve an external threat actor or an insider. Privilege escalation is a key stage of the cyberattack chain and typically involves the exploitation of a privilege escalation vulnerability, such as a system bug, misconfiguration, or inadequate access controls. The attacker can use the newly obtained privileges to steal confidential data, run administrative commands or deploy malware – and potentially do serious damage to your operating system, server applications, organization, and reputation.

In general, attackers exploit privilege escalation vulnerabilities in the initial attack phase to override the limitations of their initial user account in a system or application.

There are two main types of privilege escalation:

Horizontal privilege escalation to access the functionality and data of a different user. For example, this may mean using a compromised office workstation to gain access to other office users' data. For web applications, one example of horizontal escalation might be using session hijacking to bypass authentication and get access to another user's account on a social site, e-commerce platform, or e-banking site.

Vertical privilege escalation to obtain elevated privileges, typically of a system administrator or other power user. More dangerous is vertical privilege escalation (also called privilege elevation), where the attacker gains the rights of a more privileged account – typically the administrator or system user on Microsoft Windows or root on Unix and Linux systems.

5 Common Privileged Escalation Attack Methods

1. **Credential Exploitation**: Valid single factor credentials (username and password) will allow a typical user to authenticate against a resource. However, if a threat actor knows the username, obtaining the account's password becomes a hacking exercise.

2. **Privileged Vulnerabilities and Exploits**: Vulnerabilities are mistakes in code, design, implementation, or configuration that potentially allow malicious activity to occur via an exploit. Vulnerabilities can involve the operating system, applications, web applications, infrastructure, and so on. They can also involve the protocols, transports, and communications in between resources from wired networks, WiFi, and tone-based radio frequencies

3. **Misconfigurations**: Configuration flaws are another form of exploitable vulnerabilities. These are flaws that do not require remediation—just mitigation.

What is the difference between remediation and mitigation? Remediation implies the deployment of a software or firmware patch to correct the vulnerability. This process is commonly referred to as patch management. Mitigation, on the other hand, refers to an alteration in the existing deployment that deflects (mitigates) the risk from being exploited.

4. Malware

Malware, which includes viruses, spyware, worms, adware, ransomware, etc., refers to any class of undesirable or unauthorized software designed to have malicious intent on a resource. The intent can range from surveillance, data exfiltration, disruption, command and control,

denial of service, to extortion. Malware provides a vehicle for attackers to instrument cybercriminal activity.

Malware, like any other program, can potentially execute at any permission from standard user to administrator (root) based on the context it was originally executed within. Malware can install on a resource via:

- Vulnerability and exploit combinations
- Legitimate installers
- Weaknesses in the supply chain
- Social engineering via phishing or drive by Internet attacks.

5. Social Engineering

Social engineering attacks capitalize on the trust that people have in the communications (voice, email, text, etc.) addressed to them. If the message is well-crafted, and potentially even spoofs someone trusted, then the threat actor has already succeeded in the first step of the ruse

From a social engineering perspective, threat actors attempt to capitalize on a few key human traits to meet their goals:

- Trustworthiness: The belief that the correspondence, of any type, is from a trustworthy source.
- Credulity: The belief that the contents, as crazy or simple as they may be, are, in fact, real. This drives much of our behavior in believing "fake news".
- Sincerity: The intent of the content is in your best interest to respond or open.
- Distrust: The contents of the correspondence do not raise any concern by having misspellings and poor grammar, or by sounding like a robot corresponding on the phone.
- Curiosity: The attack technique has not been identified (as part of previous training), or the person remembers the attack vector, but does not react accordingly.
- Laziness: The correspondence initially looks good enough, but investigating the URLs and contents for malicious activity does not seem worth the effort.

If we consider each of these characteristics, we can appropriately train team members to improve resistance to social engineering attacks. The difficulty is overcoming human traits. To that end, if a team member is victimized by a social engineering attack, then the threat actor can gain access, and potentially install malware, ransomware, or escalate privileges. Successful social engineering allows the employee to "open the door" for a threat actor to conduct their nefarious mission.